Monthly Intelligence Dispatch

February 2017

The Group-IB monthly threat intelligence dispatch is an overview of the strategic changes to the cyber threat landscape, including the most important incidents, leaks and tactical changes in criminal activity.

This report includes short term forecasts and warnings, which allow you to take timely measures to protect your critical infrastructure, networks and clients. This report comes in addition to the quarterly and yearly reports that Group-IB prepares, provided alongside our operational and technical data in the Intelligence system and RFI requests from our clients completed by our analyst team.

Executive Summary

- One of the primary incidents in February 2017 was the discovery of a new widespread wave of targeted attacks on financial institutions. This is broadly suspected to be Lazarus Group, who are usually attributed as North Korean government hackers. To gain access to bank local networks, this group compromised legitimate government sites and then attempted, often successfully, to infect visitors from specific IP addresses at commercial and state financial institutions worldwide.
- The tactics of a different cybercrime group, Cobalt, have changed. Initially, after gaining access to a bank's network, they moved to attack SWIFT systems and ATM critical infrastructure in order to steal funds. Now, they have turned their efforts to stealing from card processing systems. During attacks, the group has also slightly changed their delivery method of malicious files into a targeted bank's network.
- After the arrest of the author of the Vawtrak (Neverquest) Trojan in Spain, attacks using this malware have almost entirely stopped. However, Dridex has filled this gap and attacks have begun against clients of a range of international banks.
- Members of the Swiss government CERT (GovCERT) detected that the Dridex Trojan is being used to install Anunak/Carbanak malware on victim's devices. Anunak/Carbanak was previously used for targeted attacks against banks in Russia, but at the current time it is being employed to infect PoS terminals and compromise bank cards.
- The zBot.ACB bank Trojan, which was recently tested on Canadian banks, has now started to attack Australian banks.
- The banking Trojan for Android, whose source code was published in December on a Russian-speaking hacking forum, has begun to be used in attacks on clients of banks in Turkey, German, Austria and the UK. The main vector to spread this was Google Play under the guise of Good Weather and World Weather apps.
- At the end of January 2017, researchers at Sucuri discovered a serious vulnerability in CMS WordPress. Criminals from a range of countries are now using this to spread malware and for phishing attacks.

Major events

Government sites in Poland, Mexico, Uruguay and Norway were compromised as part of a broader campaign of targeted attacks on financial institutions worldwide. On visiting the compromised government sites, users from specific IP-ranges (related to targeted financial institutions) were re-directed to malicious servers. Targeted Institutions included the Central Bank of the Russian Federation, Central Bank of Venezuela, Central Bank of Brazil, Central Bank of Chile, European Central Bank amongst others.

Trend Micro communicated that malicious programs linked to these attacks were identified in North America (mainly USA), Europe, South America, and in companies in Taiwan, Hong Kong, China and Bahrain. Victims were detected in Luxembourg, France, the Philippines, Japan, Spain, Malaysia, Norway and Romania. Trend Micro also noted attacks on Internet infrastructure providers (such as data-centers), management consulting companies, IT companies, big pharma, insurance and also aviation and higher education sectors.

The tactics, techniques and procedures (TTPs), used in these attacks are very similar to those used by the Lazarus hacking group. Attackers decided to use commercial tools, such as EnigmaProtector. Other public tools were used in the attacks, such as Neutrino Exploit kit. It is worth noting that no 0days were used.

It is also worth interesting to observe that Lazarus tried to mask their activity by pretending to be Russian hackers. Lines of code in Cyrillic were found as well as transliterated Russian in commands for communication between infected computers and C2 servers. However, the attackers made errors in the words and terms used for commands and arguments. At the current time, many security researchers are looking for additional information about the attackers' infrastructure, in order to identify more victims.

The Cobalt criminal group has changed their tactics for attacking banks. Previously they sent phishing campaigns from their servers to corporate email addresses at financial institutions. In February, Group-IB observed that Cobalt has now begun to attack companies working with banks. After successfully infecting partner companies, they then use compromised networks to send phishing emails to pre-established contacts at banks. This allows them to more effectively social engineer and bypass anti-spam. Additionally, Group-IB observed that attackers are also sending phishing mail to private email addresses of bank employees, including Gmail and Mail.ru inboxes.

As we forecast last month, Cobalt group successfully conducted attacks on ATMs, and has refocused their attacks from ATMs to card processing. New successful attacks on card processing were identified in Russia and Azerbaijan.

In the instance of attacks on card processing, criminals gain a range of advantages in money laundry and cash out. For example, they can remove all withdrawal limits on previously prepared cards to receive large amounts of funds. The main advantage of this attack methodology is that criminals don't have to steal money from the infected bank's ATMs, instead they can steal from any ATM worldwide. This allows for increased safety for mules and decreased associated money laundry service costs for the attackers, as International Law Enforcement is not able to react or enforce on incidents worldwide.

During incident response in 2016, the Swiss government CERT detected a Dridex sample that after gaining access to the victim's system as a malicious MS Office Word document, also installed the Anubak / Carbanak Trojan onto the computer. This malware was historically used for targeted attacks on Russian banks, but since then has been used to infect PoS terminals and compromise bank cards.

Dridex connects with any of the initial IP addresses listed and attempts to receive an updated config file. This contains a new selection of bot-net controllers and a list of Swiss Financial Institutions, from which Dridex will re-direct traffic on the victim's computer to commit fraud online, this is along with a list of autonomous payment programs used to commit fraud offline.

Dridex also sends the list of programs installed on the victim's computer to its C2 server. If any autonomous payment programs or programs which potentially allow for delivery of payment instructions (e.g. FTP clients), are detected on the infected computer, it will be specially marked. The C2 server can then give a command to install Anunak / Carbanak on the infected computer. If this data is not available, a fully functioning version of Dridex will be installed.

Current developments

In December 2016, Group-IB communicated that the Bridebiz criminal group, had begun to use a new Trojan, zBot.ACB, based on Zeus source code. In December and January these attackers tested their Trojan and methods for stealing from banks in Canada. However, in February they turned their attention to banks in Australia. The zBot.ACB Trojan uses an interesting method to sidestep anti-virus: it installs a php interpreter, which then encrypts and launches the main body of the Trojan when victim's OS is started.

In December 2016, on a Russian-speaking underground cybercrime forum, the source code of an Android Trojan was published. In February, evidence of its spread were identified using Google Play under the guise of Good Weather and World Weather apps. Research on these programs identified that they were based on the aforementioned and previously published source code. The Trojans were calibrated to attack clients of 68 banks in Turkey, Germany, Austria and the UK.

At the end of January 2017, researchers from Sucuri identified a serious CMS WordPress vulnerability. WordPress is one of the most popular platforms for creating websites and publications. The vulnerability allows attackers to covertly raise their privileges using REST API. This applies to WordPress versions 4.7.0 and 4.7.1. Despite the fact that developers quickly patched the vulnerability and released version 4.7.2 by 26th January 2017, a huge number of sites still are vulnerable. This total is estimated at 3 million sites worldwide. Initially, this vulnerability led to a huge growth in deface attacks. A race then took place between hacking groups for the largest number of sites attacked. They saw several methods to monetarize their attacks: spam sendouts, CEO phishing, malicious redirects, phishing, malware delivery, theft of user data, botnets, usage as file servers and also extortion.

After the arrest in Spain of 32-year-old Stanislav Lisov, author of the Vawtrak (Neverquest) Trojan, attacks using this malware almost completely stopped. Vawtrak was one of the most dangerous Trojans in recent years. Analysis of one of the servers used by Lisov revealed files containing millions of bank customer user credentials.

Forecasts and warnings

- Due to the aforementioned CMS WordPress vulnerability a growth in the total number of phishing attacks is expected, along with leaks of payment information from e-Commerce sites.
- Widespread and persistent attacks by Cobalt Group took place in Russia, Kazakhstan, Kirgizia and Moldova. Banks which have representative offices in these regions may face thefts from card processing systems.
- The Lazarus group will alter their tactics and change their server infrastructure in order to avoid detection in compromised networks.
- The zBot.ACB Trojan, will probably expand the geography of its attacks to target France and the USA.
- Members of the Vawtrak criminal group will begin to use new malware programs, such as Dridex, or will become involved in targeted attacks on banks, as occurred with members of the Carberp, Corkow and Buhtrap groups.
- In the near future, the number of attacks on clients of Banks in Turkey, Germany, Austria and the UK using zbot.ACB will increase. This Trojan is built on source code published on Russian-speaking hacking forums. The geography and number of banks targeted by this Trojan also has the potential to grow significantly.

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct ad-hoc investigations to give you the intelligence you need on the threats targeting your organization.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com